CEKBAO | Security self-assessment

Assessment date: 20 October 2026. Scope: sandbox/checker.py and the supplied offline fixtures. Status: INCOMPLETE FOR COMPETITION. Team: HMIF. All claims refer to current checked-in files only.

1. Assets, actors, trust boundaries

Potential assets in the proposed agent are payment request content, student identifier, institution policy, receipt, ledger status, evidence bundle and audit events. Trust boundaries would be user-supplied messages -> extraction/model -> policy engine -> institution policy store -> sandbox actions. In the delivered baseline, inputs are local, synthetic JSON. No network, external model or live payment data are used.

2. Verified baseline protections

- All illustrative fixtures are labeled synthetic.
- The checker does not fetch, browse, or execute a user-supplied payment link.
- It compares an HTTPS hostname for exact equality. A spoofed subdomain is not accepted.
- It separately checks policy payee and payment channel, with flags on mismatch.
- Unknown institutions return NOT_VERIFIABLE; no authoritative recipient is inferred.
- A payment slip without a matching synthetic university ledger record is flagged.
- Even a policy match sets verified_bank_settlement=false.
- Ten unit tests passed locally on the 20 October 2026 baseline. See execution evidence.

3. NOT IMPLEMENTED (security gaps)

- Real authenticated identity, secure sessions and server-side permission tiers.
- Object-level ownership checks and multi-tenant isolation.
- Real model injection resistance and tool-call allowlisting under LLM operation.
- Persistence, immutable audit logs, tamper detection and replay protection.
- Secure personal-data upload, deletion, retention controls and encryption at rest.
- Rate limiting, operational monitoring, alerts, incident response and production hardening.
- Live payment-provider verification, university policy integration and trusted data provenance checks.
- External penetration tests, privacy impact assessment and independent user testing.

4. Risk register

CRITICAL | User impersonation / unauthorized sandbox state change | No backend auth exists | Mitigation needed: signed server sessions, deny by default, object-level authorization, approval replay tests.

CRITICAL | False assurance of payment | Receipt is not proof of settlement | Current baseline always sets verified_bank_settlement=false; production must require independent authoritative confirmation.

HIGH | Forged university domain | Spoofed bank or campus URLs | Offline exact host check only; production requires curated policy sources, verified ownership, redirect/SSRF defenses.

HIGH | Prompt injection through payment messages | Model could obey attacker text | No model currently connected; validate structured extraction and forbid the LLM from invoking finance mutations.

HIGH | Personal information leakage | Receipts and passports may contain PII | No real data used in baseline; future implementation must minimize, encrypt, redact, and restrict data.

MEDIUM | False negative / false positive | Hardcoded policies become stale | Policy date, institution confirmation, source expiry, manual escalation, validated metrics required.

MEDIUM | FX estimation error | Missing intermediate fees and stale rates | Future quotes must specify date, fee scope, provider, and source; no live exchange-rate claims.

5. Permission tiers

CURRENT: none. The offline baseline is single-process without protected state. TARGET: student, reviewer, administrator. Do not claim permission-tier implementation until endpoint tests enforce authentication and cross-user isolation. This is a mandatory submission gap.

6. Residual and prohibited claims

CEKBAO currently does not verify bank deposits, obtain real institutional data, prevent fraud in the field, authenticate a user, or block financial transfers. This PDF is a transparent incomplete assessment, not a security certification.

7. Follow-up acceptance gates

Authenticate sessions; enforce object ownership; block role spoofing; refuse unknown trusted sources; reject malicious prompt instructions; make sandbox approval idempotent; prove ledger statements match synthetic fixtures; record auditable tool decisions; run and retain actual test logs; review data protection and encryption. Then update this assessment with verified tests and remaining risk.

Official checklist: https://www.pol.cmu.ac.th/public/blog/attachment/download/7a51866a-4cee-42b5-9187-fa4e1f4df411